

Documentação do Projeto – Analisador STRIDE para Diagramas

Contexto

Este projeto foi desenvolvido para o Hackathon FIAP – Fase 5, com o objetivo de aplicar técnicas de Inteligência Artificial na modelagem de ameaças de sistemas. A proposta consistiu em criar um MVP que, a partir de um diagrama de arquitetura, fosse capaz de:

1. Identificar automaticamente os componentes do sistema.
2. Aplicar a metodologia STRIDE para mapear ameaças.
3. Gerar mitigações recomendadas de forma estruturada.
4. Produzir um relatório em PDF pronto para apresentação executiva.

Fluxo Técnico do Sistema

1. O usuário acessa a aplicação Flask e realiza o upload de um diagrama.
2. O arquivo é salvo em /uploads e redimensionado para otimizar a inferência.
3. O modelo YOLOv8 (Ultralytics) carrega os pesos treinados (best.pt) e detecta os componentes.
4. Cada componente identificado é enviado para um LLM (Gemini ou OpenAI), que gera ameaças e mitigações seguindo a metodologia STRIDE.
5. O ReportLab estrutura os resultados em um relatório em PDF contendo: diagrama original, diagrama anotado, análise e mitigações.
6. O relatório final é salvo em /outputs e disponibilizado para download ao usuário.

Arquitetura da Solução

A arquitetura pode ser representada em três camadas principais:

- Frontend (Flask UI): interface web para upload/download.
- Core AI (YOLO + LLM): processamento de imagens e análise de ameaças.
- Relatórios (ReportLab): geração de documentos PDF.

Fluxo simplificado da solução:

Usuário → Flask UI → YOLO → LLM (Gemini/OpenAI) → ReportLab → PDF Final

Preparação do Dataset

- Ícones coletados de AWS e Azure.
- Script 1_gera_label.py: normalização e rótulos YOLO.
- Script 2_gera_variacoes.py: gera dataset sintético com augmentations (rotação, zoom, brilho, contraste).
- Script 3_aux_validacao_qtd_classes_images.py: relatório de distribuição de classes.
- Resultado: dataset balanceado dividido em train/val/test.

Integração com LLMs

O sistema oferece suporte a dois modelos de linguagem:

- Gemini (Google): flexível em PT-BR.
- OpenAI GPT: estrutura mais consistente nas respostas.

No frontend (Flask), o usuário pode selecionar qual LLM deseja utilizar via checkbox. Foi implementado um cache de LLM para evitar chamadas repetidas desnecessárias e reduzir custos.

Exemplo de Saída STRIDE

Spoofing:

- Falta de autenticação forte entre usuários e serviços.
- Risco de roubo de credenciais.

Mitigações:

- Implementar MFA (autenticação multifator).
- Usar autenticação baseada em certificados.

Fluxo Final de Execução

1. Usuário acessa a aplicação Flask.
2. Faz upload de um diagrama.
3. YOLO detecta os componentes.
4. Sistema anota a imagem e gera legenda.
5. Para cada componente, LLM gera ameaças e mitigações (STRIDE).
6. Relatório final em PDF é montado e disponibilizado para download.

Tecnologias Utilizadas

- YOLO (Ultralytics) → visão computacional.
- Flask → backend web.
- ReportLab → geração de PDF.
- Pillow (PIL) → manipulação de imagens.
- dotenv → variáveis de ambiente.
- LLMs: Gemini API (Google) e OpenAI GPT.

Conclusão

A solução desenvolvida entrega um fluxo automatizado e integrado que reduz drasticamente o esforço manual em modelagem de ameaças. Ela pode ser expandida para suportar novos provedores, diagramas complexos e integração em processos corporativos de segurança.